Payment Card Industry

# Data Security Standard

# Attestation of Compliance for Report on Compliance – Service Providers

**Version 4.0.1**

Publication Date: August 2024

# PCI DSS v4.0.1 Attestation of Compliance for Report on Compliance – Service Providers

**Entity Name: Dodo Payments Inc**

**Date of Report as noted in the Report on Compliance: October 31, 2025**

**Date Assessment Ended: October 31, 2025**


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

# Section 1: Assessment Information

## Instructions for Submission

This Attestation of Compliance (AOC) must be completed as a declaration of the results of the service provider's assessment against the *Payment Card Industry Data Security Standard (PCI DSS) Requirements and Testing Procedures (*"Assessment"). Complete all sections. The service provider is responsible for ensuring that each section is completed by the relevant parties, as applicable. Contact the entity(ies) to which this AOC will be submitted for reporting and submission procedures.

This AOC reflects the results documented in an associated Report on Compliance (ROC). Associated ROC sections are noted in each AOC Part/Section below.

Capitalized terms used but not otherwise defined in this document have the meanings set forth in the PCI DSS Report on Compliance Template.

| **Part 1. Contact Information** | |
|---|---|
| **Part 1a. Assessed Entity (ROC Section 1.1)** | |
| Company name: | Dodo Payments Inc |
| DBA (doing business as): | Dodo Payments |
| Company mailing address: | 5th Floor, 777c, 100 Feet Rd, HAL 2nd Stage, Doopanahalli, Indiranagar, Bengaluru, Karnataka - 560038 |
| Company main website: | https://dodopayments.com |
| Company contact name: | Ayush Agarwal |
| Company contact title: | Founder & CPTO |
| Contact phone number: | +91 9782190969 |
| Contact e-mail address: | ayush@dodopayments.com |
| **Part 1b. Assessor (ROC Section 1.1)** | |
| Provide the following information for all assessors involved in the Assessment. If there was no assessor for a given assessor type, enter Not Applicable. | |
| PCI SSC Internal Security Assessor(s) | |
| ISA name(s): | Not Applicable |
| Qualified Security Assessor | |
| Company name: | ControlCase |
| Company mailing address: | Fifty West Corporate Center<br>3975 Fair Ridge Drive, Suite D T25s, Fairfax,<br>VA 22033, USA |
| Company website: | https://www.controlcase.com/ |
| Lead Assessor name: | Alok Kumar Keshri |
| Assessor phone number: | +1 703.483.6383 |
| Assessor e-mail address: | akeshri@controlcase.com |


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

| | |
|---|---|
| Assessor certificate number: | PCI QSA<br>Certificate Number: 204-435 |

## Part 2. Executive Summary

### Part 2a. Scope Verification

**Services that were INCLUDED in the scope of the Assessment (select all that apply):**

| | |
|---|---|
| Name of service(s) assessed: | Payment Orchestrator and Merchant of Record |

Type of service(s) assessed:

| **Hosting Provider:** | **Managed Services:** | **Payment Processing:** |
|---|---|---|
| ☐ Applications / software<br>☐ Hardware<br>☐ Infrastructure / Network<br>☐ Physical space (co-location)<br>☐ Storage<br>☐ Web-hosting services<br>☐ Security services<br>☐ 3-D Secure Hosting Provider<br>☐ Multi-Tenant Service Provider<br>☐ Other Hosting (specify): | ☐ Systems security services<br>☐ IT support<br>☐ Physical security<br>☐ Terminal Management System<br>☐ Other services (specify): | ☐ POI / card present<br>☐ Internet / e-commerce<br>☐ MOTO / Call Center<br>☐ ATM<br>☐ Other processing (specify): |
| ☐ Account Management | ☐ Fraud and Chargeback | ☒ Payment Gateway/Switch |
| ☐ Back-Office Services | ☐ Issuer Processing | ☐ Prepaid Services |
| ☐ Billing Management | ☐ Loyalty Programs | ☐ Records Management |
| ☐ Clearing and Settlement | ☐ Merchant Services | ☐ Tax/Government Payments |
| ☐ Network Provider | | |
| ☐ Others (specify): | | |

***Note:*** *These categories are provided for assistance only and are not intended to limit or predetermine an entity's service description. If these categories do not apply to the assessed service, complete "Others." If it is not clear whether a category could apply to the assessed service, consult with the entity(ies) to which this AOC will be submitted.*


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

## Part 2. Executive Summary *(continued)*

### Part 2a. Scope Verification *(continued)*

**Services that are provided by the service provider but were NOT INCLUDED in the scope of the Assessment (select all that apply):**

| | |
|---|---|
| Name of service(s) not assessed: | Not Applicable |

Type of service(s) not assessed:

| **Hosting Provider:** | **Managed Services:** | **Payment Processing:** |
|---|---|---|
| ☐ Applications / software<br>☐ Hardware<br>☐ Infrastructure / Network<br>☐ Physical space (co-location)<br>☐ Storage<br>☐ Web-hosting services<br>☐ Security services<br>☐ 3-D Secure Hosting Provider<br>☐ Multi-Tenant Service Provider<br>☐ Other Hosting (specify): | ☐ Systems security services<br>☐ IT support<br>☐ Physical security<br>☐ Terminal Management System<br>☐ Other services (specify): | ☐ POI / card present<br>☐ Internet / e-commerce<br>☐ MOTO / Call Center<br>☐ ATM<br>☐ Other processing (specify): |
| ☐ Account Management | ☐ Fraud and Chargeback | ☐ Payment Gateway/Switch |
| ☐ Back-Office Services | ☐ Issuer Processing | ☐ Prepaid Services |
| ☐ Billing Management | ☐ Loyalty Programs | ☐ Records Management |
| ☐ Clearing and Settlement | ☐ Merchant Services | ☐ Tax/Government Payments |
| ☐ Network Provider | | |
| ☐ Others (specify): | | |

| | |
|---|---|
| Provide a brief explanation why any checked services were not included in the Assessment: | Not Applicable |

### Part 2b. Description of Role with Payment Cards (ROC Sections 2.1 and 3.1)

| | |
|---|---|
| Describe how the business stores, processes, and/or transmits account data. | Dodo Payments is a global Merchant of Record (MoR) that that enables SaaS companies, AI startups, and digital businesses to accept payments worldwide. It act as the contracted merchant with acquirers, processors, and payment networks, while our merchants use our platform to process customer payments. The services are offered via APIs, SDKs, hosted checkout, plugins, and merchant dashboard, ensuring secure handling of cardholder data, |


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

| | |
|---|---|
| | adherence to PCI DSS standards, and seamless integration for digital businesses across the globe.<br><br>Dodo Payments: Payment and Card Storage<br><br>• **Transmission:**<br><br>The Dodo Payments application securely collects card details (such as card number, CVV, expiry details, name on the card, nickname, customer ID, and save-for-future-usage flag) from the customer on the merchant's webpage. These details are transmitted to the Dodo Payments backend and subsequently to connectors/processors to complete transactions<br><br>• **Storage:**<br><br>When customers opt to save their card details for future use, Dodo Payments ensures secure storage of card numbers and expiry data in encrypted and hashed formats within its secure vault, following industry compliance standards.<br><br>• **Tokenization:**<br><br>Once the card details are securely encrypted and stored, Dodo Payments generates a token that links the stored card to the customer and merchant. This token is utilized to create temporary tokens for future transactions using saved cards.<br><br>**Dodo Payments: Payments with saved card:**<br><br>• **Transmission:**<br><br>During transactions with saved cards, the Dodo Payments Application retrieves tokens associated with the customer ID and generates temporary tokens. These tokens, along with masked card details, are sent to the application for customer selection.<br><br>After the customer selects a saved card and enters the CVV, the SDK transmits the temporary token and CVV to the backend. The backend securely forwards the token to the Dodo Payments vault, which decrypts the stored card details and returns them for transaction processing.<br><br>The backend then securely transmits the card details and transaction information to connectors/processors over HTTPS TLS 1.3 & 1.2 to execute the transaction |


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

| | |
|---|---|
| Describe how the business is otherwise involved in or has the ability to impact the security of its customers' account data. | If a customer chooses the option to save card data for future usage while creating a payment, then after a successful transaction, the Dodo Payments vault will store the card data in encrypted and hashed format. |
| Describe system components that could impact the security of account data. | Card Not Present |


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

## Part 2. Executive Summary *(continued)*

### Part 2c. Description of Payment Card Environment

| | |
|---|---|
| Provide a high-level description of the environment covered by this Assessment.<br>*For example:*<br>• *Connections into and out of the cardholder data environment (CDE).*<br>• *Critical system components within the CDE, such as POI devices, databases, web servers, etc., and any other necessary payment components, as applicable.*<br>• *System components that could impact the security of account data.* | Dodo Payments is a payment gateway aggregator that enables merchants to process multiple payment methods through a single integration<br>Technologies:<br>• Amazon Linux 2 (EC2)<br>• RDS Instances<br>• CloudFront<br>• Internet Gateway<br>• NAT Gateway<br>• AWS S3<br>• AWS Elasticache<br>• AWS MACIE<br>• Suricata<br>• Wazuh<br>• AWS WAF<br>• AWS Load Balancer (ELS)<br>• Antivirus - ClamAv<br>• Applications such as<br>- Dodo SDK<br>- Dodo Backend<br>- Dodo Control Center |
| Indicate whether the environment includes segmentation to reduce the scope of the Assessment.<br>(Refer to the "Segmentation" section of PCI DSS for guidance on segmentation) | ☐ Yes ☒ No |

### Part 2d. In-Scope Locations/Facilities (ROC Section 4.6)

List all types of physical locations/facilities (for example, corporate offices, data centers, call centers and mail rooms) in scope for this Assessment.

| Facility Type | Total Number of Locations<br>(How many locations of this type are in scope) | Location(s) of Facility<br>(city, country) |
|---|---|---|
| *Example: Data centers* | *3* | *Boston, MA, USA* |
| AWS Cloud Datacenter | *1* | Mumbai ap-south-1 |


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

## Part 2. Executive Summary *(continued)*

### Part 2e. PCI SSC Validated Products and Solutions (ROC Section 3.3)

Does the entity use any item identified on any PCI SSC Lists of Validated Products and Solutions*?

☐ Yes ☒ No

Provide the following information regarding each item the entity uses from PCI SSC's Lists of Validated Products and Solutions:

| Name of PCI SSC validated Product or Solution | Version of Product or Solution | PCI SSC Standard to which Product or Solution Was Validated | PCI SSC Listing Reference Number | Expiry Date of Listing |
|---|---|---|---|---|
| Not Applicable | Not Applicable | Not Applicable | Not Applicable | Not Applicable |

* For purposes of this document, "Lists of Validated Products and Solutions" means the lists of validated products, solutions, and/or components, appearing on the PCI SSC website (www.pcisecuritystandards.org) (for example, 3DS Software Development Kits, Approved PTS Devices, Validated Payment Software, Point to Point Encryption (P2PE) solutions, Software-Based PIN Entry on COTS (SPoC) solutions, Contactless Payments on COTS (CPoC) solutions), and Mobile Payments on COTS (MPoC) products.


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

## Part 2. Executive Summary *(continued)*

### Part 2f. Third-Party Service Providers
*(***ROC Section 4.4***)*

For the services being validated, does the entity have relationships with one or more third-party service providers that:

| | |
|---|---|
| • Store, process, or transmit account data on the entity's behalf (for example, payment gateways, payment processors, payment service providers (PSPs, and off-site storage)) | ☐ Yes ☒ No |
| • Manage system components included in the entity's Assessment (for example, via network security control services, anti-malware services, security incident and event management (SIEM), contact and call centers, web-hosting companies, and IaaS, PaaS, SaaS, and FaaS cloud providers) | ☒ Yes ☐ No |
| • Could impact the security of the entity's CDE (for example, vendors providing support via remote access, and/or bespoke software developers). | ☐ Yes ☒ No |

**If Yes:**

| **Name of Service Provider:** | **Description of Services Provided:** |
|---|---|
| Amazon Web Services, Inc | Cloud hosting provider |
| Airwallex | Payment Processor |
| Stripe | Payment Processor |
| Cashfree | Payment Processor |

***Note:*** *Requirement 12.8 applies to all entities in this list.*


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

## Part 2. Executive Summary *(continued)*

### Part 2g. Summary of Assessment (ROC Section 1.8.1)

*Indicate below all responses provided within each principal PCI DSS requirement.*

For all requirements identified as either "Not Applicable" or "Not Tested," complete the "Justification for Approach" table below.

***Note:*** *One table to be completed for each service covered by this AOC. Additional copies of this section are available on the PCI SSC website.*

*Name of Service Assessed:* Payment Orchestrator and Merchant of Record

| PCI DSS Requirement | Requirement Finding<br>More than one response may be selected for a given requirement. Indicate all responses that apply. | | | | Select If a Compensating Control(s) Was Used |
|---|---|---|---|---|---|
| | In Place | Not Applicable | Not Tested | Not in Place | |
| Requirement 1: | ☒ | ☒ | ☐ | ☐ | ☐ |
| Requirement 2: | ☒ | ☒ | ☐ | ☐ | ☐ |
| Requirement 3: | ☒ | ☒ | ☐ | ☐ | ☐ |
| Requirement 4: | ☒ | ☒ | ☐ | ☐ | ☐ |
| Requirement 5: | ☒ | ☒ | ☐ | ☐ | ☐ |
| Requirement 6: | ☒ | ☒ | ☐ | ☐ | ☐ |
| Requirement 7: | ☒ | ☒ | ☐ | ☐ | ☐ |
| Requirement 8: | ☒ | ☒ | ☐ | ☐ | ☒ |
| Requirement 9: | ☒ | ☒ | ☐ | ☐ | ☐ |
| Requirement 10: | ☒ | ☒ | ☐ | ☐ | ☐ |
| Requirement 11: | ☒ | ☒ | ☐ | ☐ | ☐ |
| Requirement 12: | ☒ | ☒ | ☐ | ☐ | ☐ |
| Appendix A1: | ☐ | ☒ | ☐ | ☐ | ☐ |
| Appendix A2: | ☐ | ☒ | ☐ | ☐ | ☐ |

**Justification for Approach**


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

| | |
|---|---|
| For any Not Applicable responses, identify which sub-requirements were not applicable and the reason. | **1.3.3 - Wireless networks are not present Hence this control is not applicable.**<br>**2.3.1 - Wireless networks are not present Hence this control is not applicable.**<br>**2.3.2 - Wireless networks are not present Hence this control is not applicable.**<br>**3.3.2 - Does not store sensitive authentication data electronically prior to completion of authorization. Hence, this control is not applicable**<br>**3.3.3 - Does not store sensitive authentication data electronically prior to completion of authorization. Hence, this control is not applicable**<br>**3.4.2 - Does not store sensitive authentication data electronically prior to completion of authorization. Hence, this control is not applicable**<br>**3.5.1.2 - Does not render PAN unreadable using disk-level or partition-level encryption. Hence this control is not applicable.**<br>**3.5.1.3 - Does not render PAN unreadable using disk-level or partition-level encryption. Hence this control is not applicable**<br>**3.6.1.3 - Does not render PAN unreadable using disk-level or partition-level encryption. Hence this control is not applicable**<br>**3.7.6 – Dodo Payment is not having manual cleartext cryptographic key-management operations performed by personnel. Hence this control is not applicable.**<br>**3.7.9 - Does not share cryptographic keys with its customers. Hence this control is not applicable**<br>**4.2.1.2 - Wireless networks are not present Hence this control is not applicable.**<br>**4.2.2 - End-user messaging technologies are not being used to send cardholder data .Hence this control is not applicable.**<br>**5.2.3 -No system components that are not at risk for malware. Hence this control is not applicable.**<br>**5.2.3.1 - No system components that are not at risk for malware. Hence this control is not applicable.**<br>**5.3.3 - There are no removable electronic media in scope. Hence this control is not applicable.**<br>**6.2.3.1 - There were no manual code Review done in scoped environment, Hence Not Applicable**<br>**6.4.1 - This control will be superseded by Requirement 6.4.2 after 31 March 2025. Hence this control is not applicable.**<br>**6.5.2 - No significant change. Hence this control is not applicable.**<br>**7.2.5.1 - There is no application or system account hence it is not applicable** |


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

| | |
|---|---|
| | **8.2.3 - there are no service providers with remote access in the scoped environment. Hence, this control will not be applicable.**<br>**8.2.7 - Third parties are not provided access to scoped environment. Hence, this control is not applicable**<br>**8.3.10 - This control will be superseded by Requirement 8.3.10.1 after 31 March 2025. Hence this control is not applicable.**<br>**8.6.1 - Do not have any system and application accounts in scoped environment. Hence this control is not applicable**<br>**8.6.2 - Do not have any system and application accounts in scoped environment. Hence this control is not applicable.**<br>**8.6.3 - There is no system or application accounts used hence it is not applicable**<br>**9.4.1 - This control is not applicable as physical media is not used to store CHD.**<br>**9.4.1.1 - This control is not applicable as physical media is not used to store CHD.**<br>**9.4.1.2 - This control is not applicable as physical media is not used to store CHD.**<br>**9.4.2 - This control is not applicable as physical media is not used to store CHD.**<br>**9.4.3 - This control is not applicable as physical media is not used to store CHD.**<br>**9.4.4 - This control is not applicable as physical media is not used to store CHD.**<br>**9.4.5 - This control is not applicable as physical media is not used to store CHD.**<br>**9.4.5.1 - This control is not applicable as physical media is not used to store CHD.**<br>**9.4.6 - This control is not applicable as physical media is not used to store CHD.**<br>**9.4.7 - This control is not applicable as physical media is not used to store CHD.**<br>**9.5.1 - POI Device not available in environments. Hence, this requirement is not applicable.**<br>**9.5.1.1 - POI Device not available in environments. Hence, this requirement is not applicable.**<br>**9.5.1.2 - POI Device not available in environments. Hence, this requirement is not applicable.**<br>**9.5.1.2.1 - POI Device not available in environments. Hence, this requirement is not applicable.**<br>**9.5.1.3 - POI Device not available in environments. Hence, this requirement is not applicable.**<br>**10.7.1 - Not Applicable as superseded by Requirement 10.7.2**<br>**11.2.1 -There is no Wireless network .Hence this control is not applicable**<br>**11.2.2 -There is no Wireless network .Hence this control is not applicable** |


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

| | |
|---|---|
| | **11.3.1.3 - Not Applicable as there is not any significant changes.**<br>**11.3.2.1 - Not Applicable as there is not any significant changes.**<br>**11.4.4 - No exploitable vulnerabilities and security weaknesses identified during External penetration testing**<br>**11.4.5 - There was no segmentation performed in the scope. Hence this control is not applicable**<br>**11.4.6 - There was no segmentation performed in the scope. Hence this control is not applicable**<br>**11.4.7 - Not a multi-tenant service provider. Hence, this requirement is not applicable.**<br>**12.3.2 -Not any customized approach used in the scope. Hence, this requirement is not applicable.**<br>**12.5.3 - There was no segmentation performed in the scope. Hence this control is not applicable**<br>**A1.1.1, A1.1.2, A1.1.3, A1.1.4, A1.2.1, A1.2.2, A1.2.3 Not applicable as Dodo Payment is not a multi-tenant service provider.**<br>**A2.1.1, A2.1.2, A2.1.3 - Not applicable as Dodo Payment does not have POS devices within their scoped environment.** |
| For any Not Tested responses, identify which sub-requirements were not tested and the reason. | **Not Applicable** |


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

# Section 2 Report on Compliance

(**ROC Sections 1.2 and 1.3**)

| | |
|---|---|
| Date Assessment began:<br>***Note:*** *This is the first date that evidence was gathered, or observations were made.* | September 01, 2025 |
| Date Assessment ended:<br>***Note:*** *This is the last date that evidence was gathered, or observations were made.* | October 31, 2025 |
| Were any requirements in the ROC unable to be met due to a legal constraint? | ☐ Yes ☒ No |
| Were any testing activities performed remotely? | ☒ Yes ☐ No |


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

# Section 3 Validation and Attestation Details

## Part 3. PCI DSS Validation (ROC Section 1.7)

**This AOC is based on results noted in the ROC dated** *(Date of Report as noted in the* ***ROC*** **October 31, 2025***)*.

Indicate below whether a full or partial PCI DSS assessment was completed:

☒ **Full Assessment** – All requirements have been assessed and therefore no requirements were marked as Not Tested in the ROC.

☐ **Partial Assessment** – One or more requirements have not been assessed and were therefore marked as Not Tested in the ROC. Any requirement not assessed is noted as Not Tested in Part 2g above.

Based on the results documented in the ROC noted above, each signatory identified in any of Parts 3b-3d, as applicable, assert(s) the following compliance status for the entity identified in Part 2 of this document *(select one)**:***

| | |
|---|---|
| ☒ | **Compliant:** All sections of the PCI DSS ROC are complete, and all assessed requirements are marked as being either In Place or Not Applicable, resulting in an overall **COMPLIANT** rating; thereby *DODO Payments Inc* has demonstrated compliance with all PCI DSS requirements except those noted as Not Tested above. |
| ☐ | **Non-Compliant:** Not all sections of the PCI DSS ROC are complete, or one or more requirements are marked as Not in Place, resulting in an overall **NON-COMPLIANT** rating; thereby *(Service Provider Company Name)* has not demonstrated compliance with PCI DSS requirements.<br><br>**Target Date** for Compliance: *YYYY-MM-DD*<br><br>An entity submitting this form with a Non-Compliant status may be required to complete the Action Plan in Part 4 of this document. Confirm with the entity to which this AOC will be submitted before completing Part 4. |
| ☐ | **Compliant but with Legal exception:** One or more assessed requirements in the ROC are marked as Not in Place due to a legal restriction that prevents the requirement from being met and all other assessed requirements are marked as being either In Place or Not Applicable, resulting in an overall **COMPLIANT BUT WITH LEGAL EXCEPTION** rating; thereby *(Service Provider Company Name)* has demonstrated compliance with all PCI DSS requirements except those noted as Not Tested above or as Not in Place due to a legal restriction.<br><br>This option requires additional review from the entity to which this AOC will be submitted.<br><br>*If selected, complete the following:* |

| Affected Requirement | Details of how legal constraint prevents requirement from being met |
|---|---|
| | |
| | |
| | |


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

## Part 3. PCI DSS Validation *(continued)*

### Part 3a. Service Provider Acknowledgement

**Signatory(s) confirms:**
(Select all that apply)

| | |
|---|---|
| ☒ | The ROC was completed according to *PCI DSS*, Version *4.0.1* and was completed according to the instructions therein. |
| ☒ | All information within the above-referenced ROC and in this attestation fairly represents the results of the Assessment in all material respects. |
| ☒ | PCI DSS controls will be maintained at all times, as applicable to the entity's environment. |

### Part 3b. Service Provider Attestation

| | |
|---|---|
| *Signature of Service Provider Executive Officer* ↑ | Date: **October 31, 2025** |
| Service Provider Executive Officer Name: **Ayush Agarwal** | Title: **Founder & CPTO** |

### Part 3c. Qualified Security Assessor (QSA) Acknowledgement

| | |
|---|---|
| If a QSA was involved or assisted with this Assessment, indicate the role performed: | ☒ QSA performed testing procedures. |
| | ☐ QSA provided other assistance.<br>If selected, describe all role(s) performed: |

| | |
|---|---|
| *Signature of Lead QSA* ↑ | Date: **October 31, 2025** |
| Lead QSA Name: **Alok Kumar Keshri** | |

| | |
|---|---|
| *Signature of Duly Authorized Officer of QSA Company* ↑ | Date: **October 31, 2025** |
| Duly Authorized Officer Name: **Amol Sawant** | QSA Company: **ControlCase** |

### Part 3d. PCI SSC Internal Security Assessor (ISA) Involvement

| | |
|---|---|
| If an ISA(s) was involved or assisted with this Assessment, indicate the role performed: | ☐ ISA(s) performed testing procedures. |
| | ☐ ISA(s) provided other assistance.<br>If selected, describe all role(s) performed: |


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*

## Part 4. Action Plan for Non-Compliant Requirements

*Only complete Part 4 upon request of the entity to which this AOC will be submitted, and only if the Assessment has Non-Compliant results noted in Section 3.*

If asked to complete this section, select the appropriate response for "Compliant to PCI DSS Requirements" for each requirement below. For any "No" responses, include the date the entity expects to be compliant with the requirement and provide a brief description of the actions being taken to meet the requirement.

| PCI DSS Requirement | Description of Requirement | Compliant to PCI DSS Requirements (Select One) | | Remediation Date and Actions (If "NO" selected for any Requirement) |
|---|---|---|---|---|
| | | YES | NO | |
| 1 | Install and maintain network security controls | ☐ | ☐ | |
| 2 | Apply secure configurations to all system components | ☐ | ☐ | |
| 3 | Protect stored account data | ☐ | ☐ | |
| 4 | Protect cardholder data with strong cryptography during transmission over open, public networks | ☐ | ☐ | |
| 5 | Protect all systems and networks from malicious software | ☐ | ☐ | |
| 6 | Develop and maintain secure systems and software | ☐ | ☐ | |
| 7 | Restrict access to system components and cardholder data by business need to know | ☐ | ☐ | |
| 8 | Identify users and authenticate access to system components | ☐ | ☐ | |
| 9 | Restrict physical access to cardholder data | ☐ | ☐ | |
| 10 | Log and monitor all access to system components and cardholder data | ☐ | ☐ | |
| 11 | Test security systems and networks regularly | ☐ | ☐ | |
| 12 | Support information security with organizational policies and programs | ☐ | ☐ | |
| Appendix A1 | Additional PCI DSS Requirements for Multi-Tenant Service Providers | ☐ | ☐ | |
| Appendix A2 | Additional PCI DSS Requirements for Entities using SSL/early TLS for Card-Present POS POI Terminal Connections | ☐ | ☐ | |

*Note: The PCI Security Standards Council is a global standards body that provides resources for payment security professionals developed collaboratively with our stakeholder community. Our materials are accepted in numerous compliance programs worldwide. Please check with your individual compliance accepting organization to ensure that this form is acceptable in their program. For more information about PCI SSC and our stakeholder community please visit: https://www.pcisecuritystandards.org/about_us/*


*© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.*